武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第六章　访问控制模型
(Access Control Model)

LISS
空天信息安全与可信计算
教育部重点实验室

访问控制模型

1、 访问控制的基本概念

2、 自主访问控制

3、 强制访问控制

4、 基于角色的访问控制

5、 Chinese Wall

6、 访问控制机制

1、访问控制的基本概念

- 基本目标：

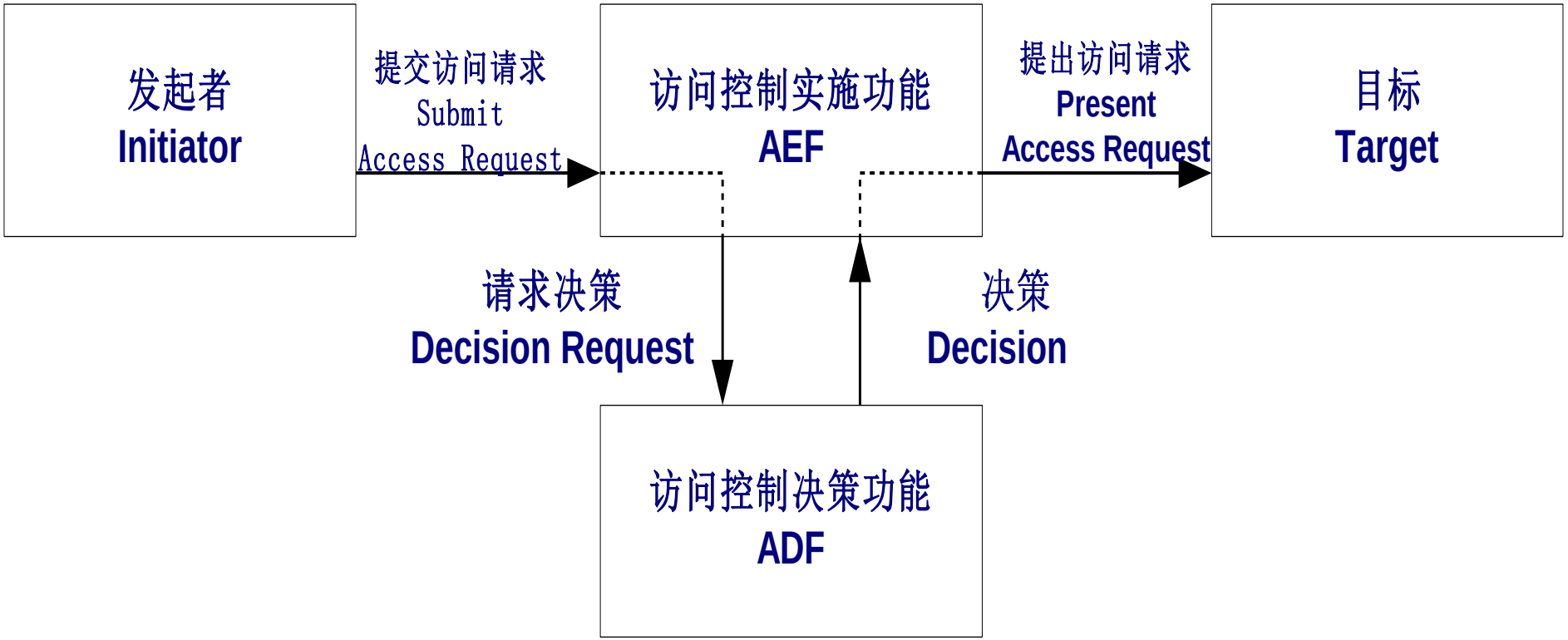
  依据授权对提出的资源访问请求进行控制，防止对任何资源（如计算资源、通信资源或信息资源）进行未授权的访问。

  未授权的访问包括：未经授权的使用、泄露、修改、销毁信息以及颁发指令等。

LISS
空天信息安全与可信计算
教育部重点实验室

银行为例

访问控制模型基本组成


发起者
Initiator
提交访问请求
Submit
Access Request
访问控制实施功能
AEF
提出访问请求
Present
Access Request
目标
Target
请求决策
Decision Request
决策
Decision
访问控制决策功能
ADF

访问控制的基本概念

三要素：

- 主体（**Subject**）：访问的发起者

  - 试图访问某个目标的用户或者是用户行为的代理。主体通常为进程或用户。

- 客体（**Object**）：

  -可供访问的各种软硬件资源。

- 策略**(Policy)**

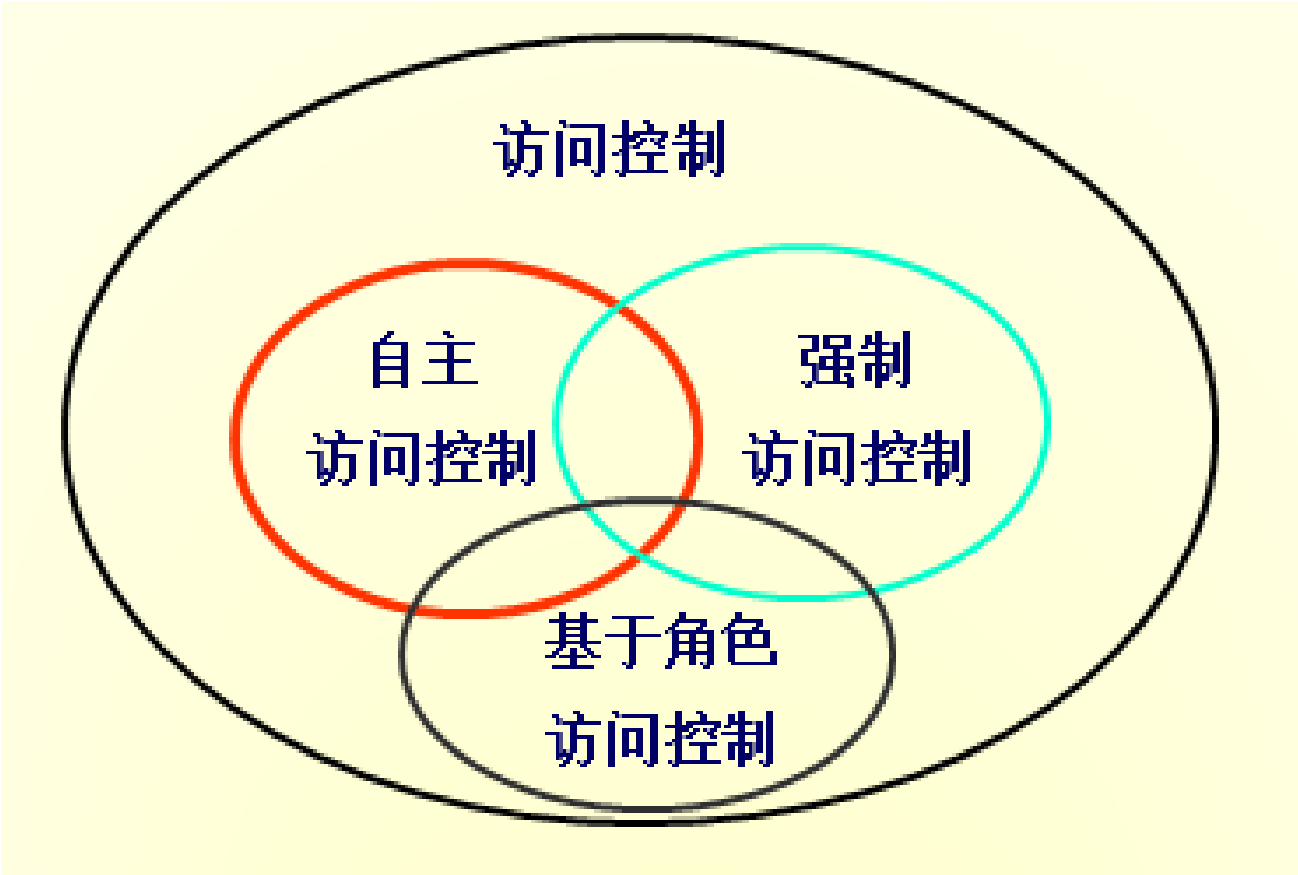
  - 定义了主体对客体的权限

访问控制的基本概念

- 策略(Policy)-访问控制的核心

  - 定义了主体对客体的访问规则集
  - 体现了一种授权行为，即主体对客体的使用权限
  - 决定了用户能做什么

访问控制框架与模型



2、自主访问控制

自主访问控制（DAC）：Discretionary Access Control

- 是一种最为普遍的访问控制手段
- 其依据是用户的身份和授权，并为系统中的每个用户（或用户组）和客体规定了用户允许对客体进行访问的方式。
- 每个用户对客体进行访问的要求都要经过权限检验，如果授权中允许用户以这种方式访问客体，则访问就可以得到允许，否则就不予许可。

2、自主访问控制

- 自主访问控制允许用户自主地在系统中规定谁可以存取它的资源实体，例如用户（包括用户程序和用户进程）可选择同其他用户一起共享某个文件。
- 自主：指具有授与某种访问权力的主体能够自己决定是否将访问权限授予其他的主体。
- 安全操作系统需要具备的特征之一就是自主访问控制，它基于对主体或主体所属的主体组的识别来限制对客体的存取

2、自主访问控制

- **优点：**

  ✓ 主体的拥有者负责设置访问权限。根据主体的身份和授权来决定访问模式，比较灵活。

- **缺点：**

  ✓ 权限在转移过程中，其访问权限关系会被改变。

  如，用户A可以将其对客体目标O的访问权限传递给用户B，从而使不具备对O访问权限的B也可以访问O，这样做很容易产生安全漏洞，所以自主访问控制的安全级别很低。

2、自主访问控制

- **缺点：**

  ✓ 当用户数量多、管理数据量大时，由于访问控制的粒度是单个用户，访问控制策略会很庞大。

  当组织内的人员发生变化（升迁、换岗、招聘、离职）、工作职能发生变化（新增业务）时，访问控制策略的修改变得异常困难。

3、强制访问控制

强制访问控制（MAC）：Mandatory Access Control)

- 系统对所有主体及其所控制的客体（例如：进程、文件、段、设备）指定敏感标记，这些标记是等级分类和非等级类别的组合，它们是实施强制访问控制的依据。
- MAC通过安全标签实现单向信息流通模式。

3、强制访问控制

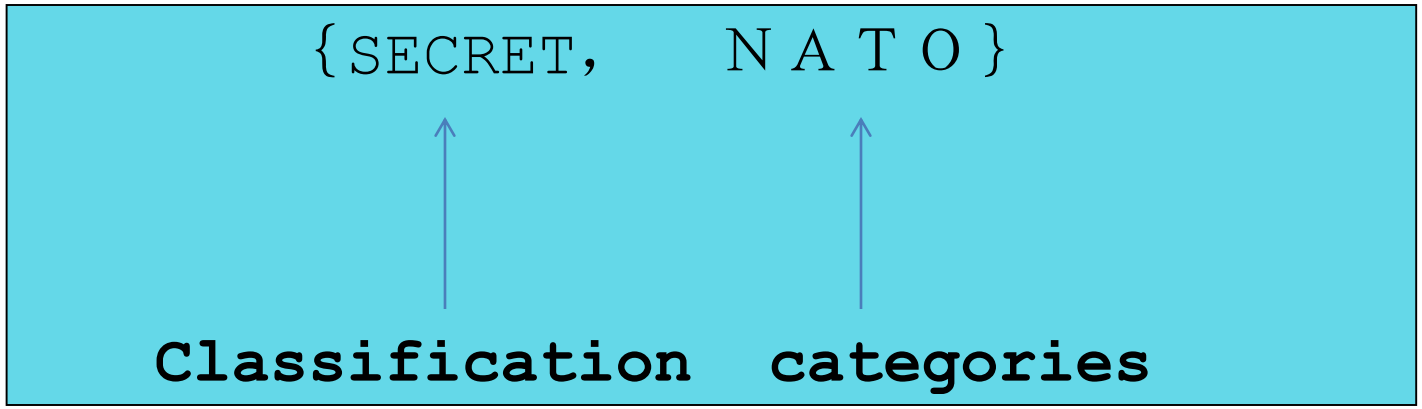
强制访问控制（MAC）：Mandatory Access Control)

所谓“强制”就是安全属性由系统管理员人为设置，或由操作系统自动地按照严格的安全策略与规则进行设置，用户和他们的进程不能修改这些属性。

3、强制访问控制

- 系统根据主体和客体的敏感标记来决定访问模式。敏感标记一般有密级和范畴组成。

如：



MAC通过安全标签实现单向信息流通模式。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

BLP（Bell-LaPadula)模型

- 是由Bell和Lapadula在第一次联合设计安全的多用户操作系统Multics时提出的。
- BLP是描述访问控制的机密性问题的状态机模型，访问许可通过控制矩阵和安全级别来定义，安全策略防止信息从高安全级别流向低安全级别，这些策略一般称为多级安全（MLS）策略。
- BLP主要考虑主体在查看或修改一个客体时发生的信息流动

3、强制访问控制

例： 军事安全策略

每个军官和文件都划分一个安全级别：

- 安全级别=<密级，业务范围>
  - 密级：绝密（topsecret)、机密(secret)、秘密(classified)、公开(unclassified)
  - 范畴：NATO（北约类）、NUCLEAR（核武器类）、NMD（导弹防御系统类）
- 一个军官要能阅读某一文件，*军官的密级必须大于等于该文件的密级，而且军官的业务范围必须包含文件的业务范围*。例如，设军官A和文件F_1的安全级别为

  A: < topsecret , NATO 、NUCLEAR 、NMD>,

  F_1: < secret , NATO 、NUCLEAR >,

则军官A可以阅读文件F_1。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

- 一个军官要能写某一文件，*军官的密级必须小于等于该文件的密级，而且军官的业务范围必须被文件的业务范围所包含*。

  例如，设军官B和文件F_2的安全级别为

  B：< topsecret ，NATO 、NUCLEAR 、NMD>，

  F_2：< secret ，NATO 、NUCLEAR >，

所以军官B不可以写文件F_2。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

BLP模型

- *每个主体和客体都划分一个密级 A;*
- *每个主体和客体都划分一个业务范围 C;*
- 设SC为全体安全级别<A, C>的集合：

$$SC = \langle A, C \rangle$$

- 定义二元关系≤如下，并称关系≤为*支配*：

$$SC = \langle A, C \rangle,\ SC' = \langle A', C' \rangle,$$

则SC ≤ SC' ，iff A≤A' and C ⊆ C' 。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

BLP模型

- 对于集合SC中的任意元素X，Y，Z都有

  自反性　X≤X；

  传递性　如果X≤Y，而且Y≤Z，则X≤Z；

  反对称性　如果X≤Y，而且Y≤X，则X＝Y。

- 如上定义的关系≤为*偏序关系*，集合SC为*偏序集合*，记为[SC，≤]。

3、强制访问控制

BLP模型

- 在[SC, ≤]中定义运算⊕、⊙如下：

  $\langle A, C\rangle \oplus \langle A', C'\rangle = \langle \max(A, A'), C \cup C'\rangle$ ，

  $\langle A, C\rangle \odot \langle A', C'\rangle = \langle \min(A, A'), C \cap C'\rangle$ 。

显然，[SC, ≤]的最高安全级别和最低安全级别分别是

HIGH＝<Topsecret，{全体属类}>，

LOW＝< unclassified，{}>。

- *所以[SC, ≤]构成代数格。*

LISS
空天信息安全与可信计算
教育部重点实验室

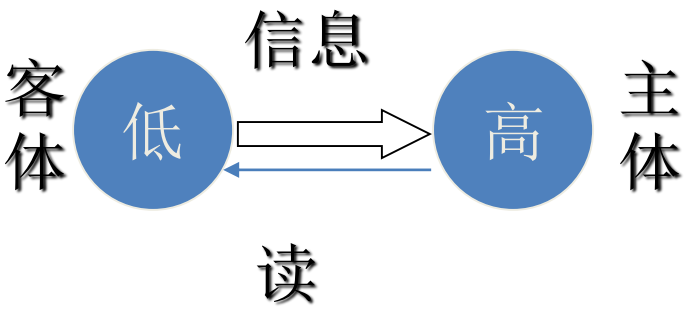
3、强制访问控制

BLP模型

- 简单安全原则（向下读）

  主体 s对客体 o具有读访问权，当且仅当 S支配 O，即

  $\langle A_o, C_o \rangle \leqslant \langle A_s, C_s \rangle$。



- 例如，设军官A和文件F_1的安全级别为

  F_1：< secret , NATO 、NUCLEAR >,

  A：< topsecret , NATO 、NUCLEAR 、NMD>,

  所以军官A可以读文件F_1。

LISS
空天信息安全与可信计算
教育部重点实验室

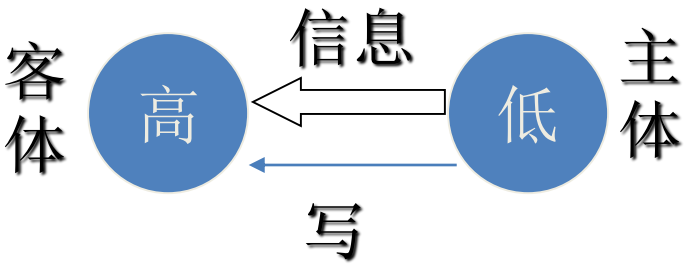
3、强制访问控制

BLP模型

- *特性（向上写）

  主体 s对客体 o具有写访问权，当且仅当 O支配 S，即

  $\langle A_o, C_o \rangle \geqslant \langle A_s, C_s \rangle$。



例如，设军官B和文件F_2的安全级别为

F_2: < secret , NATO 、NUCLEAR >,

B: < topsecret , NATO 、NUCLEAR 、NMD>,

所以军官B不可以写文件F_2。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

- 稳定原则

  主体和客体的安全级别在它们被引用时必须保持不变。

3、强制访问控制

BLP模型

- *强制性*

  通过比较主体和客体之间的安全级别的支配关系来控制主体对客体的访问。

  主体不能自主的授予客体权力或回收权力。

- *优缺点*

  更安全：可以阻止某些类型的特洛伊木马攻击。

  缺点是对用户限制较多，用户感到不够灵活。

  主要保护秘密性，缺乏对真实性和完整性保护。

- *B级以上操作系统：多数安全操作系统，MULTICS*

3、强制访问控制

BIBA完整性模型

- 是由Kenneth J. Biba于1977年设计的一个著名的用于保护完整性的模型。
- Biba模型解决了当位于较低安全级内的主体能够向位于较高安全级内的客体写入时，以及主体能够读取较低安全级的数据时，受到威胁的数据的完整性问题。

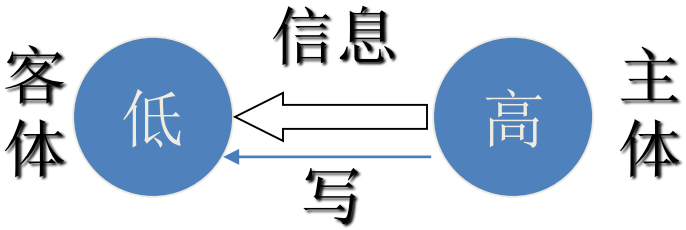
3、强制访问控制

BIBA的两条主要规则：

- 第一条规则“不能向上写”；（一个主体不能把数据写入位于较高完整性级别的客体。）
- 第二条规则“不能向下读”（主体不能从较低的完整性级别读取数据）；

3、强制访问控制

➢ 设l是从主客体到完整性等级的一个函数，则访问规则是：



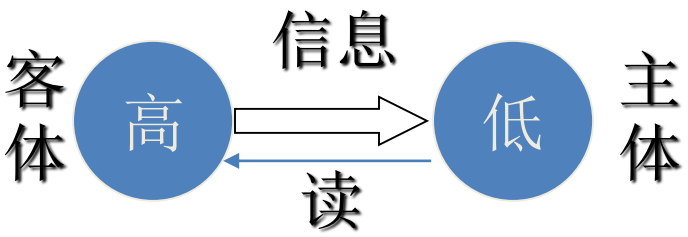
- 写规则：对任意的主体s和客体o，当且仅当l(o) ≤l(s),允许写操作。

这一规则不允许一个主体向更高等级的可信任客体进行写入，以防止不正确的或者是伪造的信息。

3、强制访问控制

➢ 设l是从主客体到完整性等级的一个函数，

则访问规则是：



- 读规则：对任意的主体s和客体o,当且仅当l(o) ≥l(s),允许读操作。

这一规则不允许一个主体读更低层次的数据，防止低级数据“污染”主体或主体的操作，降低其完整性级别。

LISS
空天信息安全与可信计算
教育部重点实验室

3、强制访问控制

BIBA模型

- *简单性*
- *容易与BLP模型结合*

通过在标记中增加完整性标记，可实现同时控制系统访问的机密性和完整性。

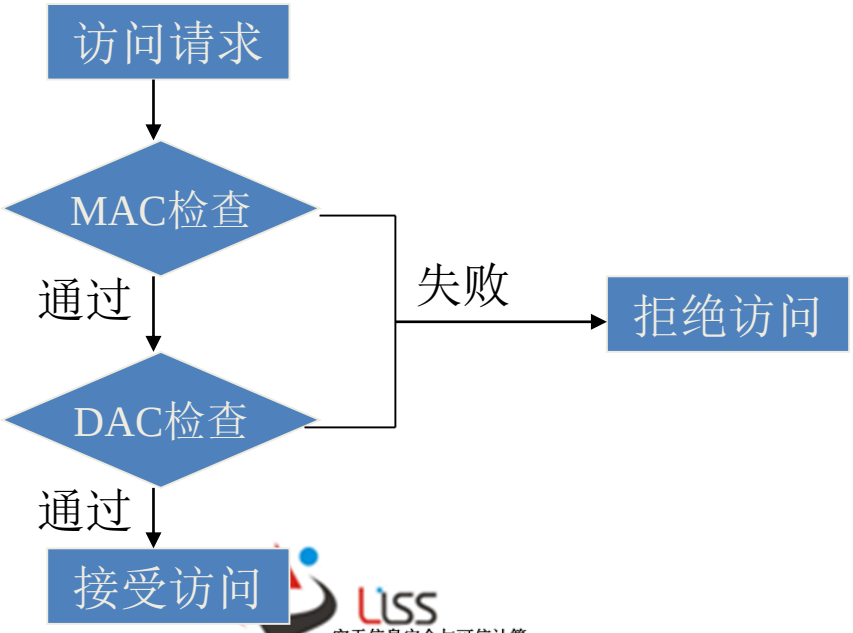
➢ *缺点*

- *完整性标签确定的困难性。*
- *实施的复杂性。*

3、强制访问控制

MAC和DAC的应用

- *在C级操作系统中应用DAC访问控制模型*
- *在B级以上操作系统中应用MAC，或将MAC和DAC联合应用*



LISS
空天信息安全与可信计算
教育部重点实验室

4、基于角色的访问控制

基于角色的访问控制（RBAC）：Role-Based Access Control

- 由NIST的Ferraiolo等人在90年代提出。
- NIST成立专门机构进行研究。
- 96年提出一个较完善的基于角色的访问控制参考模型RBAC96。

4、基于角色的访问控制

RBAC的基本思想

- 根据用户在一个组织中担任的角色来确定对其所的授权。

  如，张三今天担任科长，则应授予他科长的权限，明天他提升为处长，则应授予他处长的权限。一个用户担任一个角色后，便可以拥有该角色的权限，但是他不能将权限转授给别人。

- RBAC是不是DAC

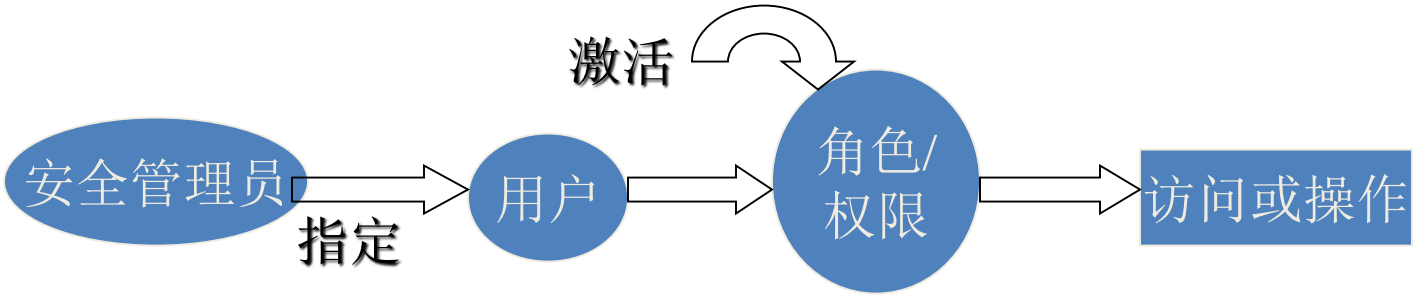
  虽然一个用户担任一个角色后，便可以拥有该角色的权限，但是他不能将权限转授给别人。

  如，在医院里医生拥有开处方的权限，但他不能将开处方的权限转给护士。

4、基于角色的访问控制

RBAC的基本概念

- *RBAC的基本思想是根据用户所担任的角色来决定用户的在系统中的访问权限。*
- *一个用户必须扮演某种角色，而且还必须激活这一角色，才能对一个对象进行访问或执行某种操作。*



LISS
空天信息安全与可信计算
教育部重点实验室

4、基于角色的访问控制

RBAC的基本概念

- 用户（User）

♣访问计算机资源的主体。用户集合为 U.

- 角色（role）

♣一种岗位，代表一种资格、权利和责任。角色集合为 R.

- 权限（permission）

♣对客体的操作权力。权限集合为 P.

- 用户分配（User Assignment）

♣将用户与角色关联。

♣用户分配集合为$UA=\{(u,r)|u\in U, r\in R\}$.

♣用户 u与角色 r关联后，将拥有 r的权限。

4、基于角色的访问控制

RBAC的基本概念

- 权限分配（Permission Assignment）

♣将角色与权限关联。

♣权限分配集合为PA={(p, r)|p∈P, r∈R} .

♣权限 p与角色 r关联后，角色 r将拥有权限 p。

- 激活角色（Actve Role）

♣角色只有激活才能起作用，否则不起作用。

♣通过会话激活角色。

- 会话（Session）

♣用户要访问系统资源时，必须先建立一个会话。

♣一次会话仅对应一个用户。一次会话可激活几个角色。

4、基于角色的访问控制

RBAC的基本机制

- *RBAC的授权机制：*

  a. *分为两步：* ♣*将访问权限分配给角色*
  ♣*将角色分配给用户*

  b. *授权要满足安全约束条件。*
  ♣ *最小特权原则*
  ♣ *职责分离原则*
  ♣ *角色互斥原则*
  ♣ *角色激活限制原则*

  c. *角色分级，高级角色可以继承低级角色的访问权限。*

4、基于角色的访问控制

RBAC的基本机制

- *RBAC用户与角色的关系：（多对多关系）*
  - a. *一个用户可担当多个角色*
  - b. *一个角色可分配给多个用户*
- *角色和权限之间的关系：（多对多的关系）*
  - a. *一个角色可以拥有多个访问权限，*
  - b. *不同的角色也可以拥有相同的权限。*
- *角色和角色的关系：（分级关系）*

  高级角色可以继承低级角色的访问权限。

4、基于角色的访问控制

RBAC的基本机制

- 角色分级

  a. 角色分级是组织角色的一种自然方法。

  b. 角色分级的结果将导致一个角色可以直接或间接地继承另一角色的访问权限。

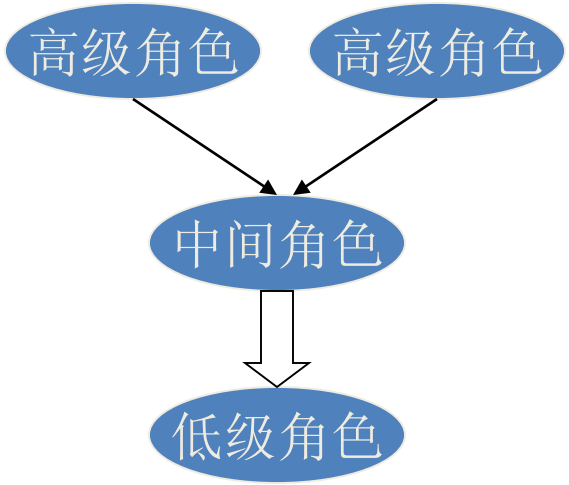
  c. 直接继承：相邻角色之间的继承。

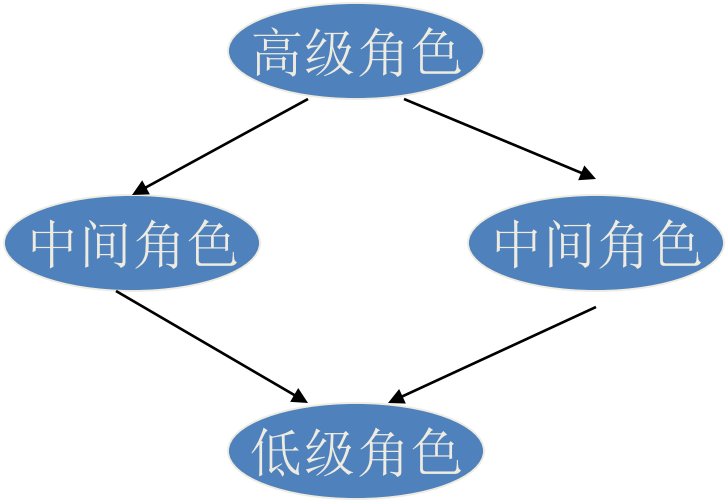
  d. 间接继承：非相邻角色之间的继承。

  e. 高低级角色之间的继承关系是一种偏序关系。

4、基于角色的访问控制

角色分级(role hierarchy)继承关系





LISS
空天信息安全与可信计算
教育部重点实验室

4、基于角色的访问控制

RBAC的基本机制

- *会话：*

  a. *用户要访问系统资源时，必须先建立一个会话。*

  b. *一次会话仅仅对应一个用户。*

  c. *一次会话中可以激活几个角色。*

  d. *角色激活要满足安全约束。*

- *激活：*

  a. 激活是角色的一种状态。

  b. 通过会话激活角色。

  c. 只有激活的角色才起作用。

4、基于角色的访问控制

RBAC的基本机制

- 安全约束
  - 约束是设计高级安全策略的一个强有力的机制。
  - 各个环节施加安全约束，以实现不同的安全策略。
  - 可以定义在系统层，也可以定义在应用层。
  - 可以是事件触发的，也可以不是事件触发的。
- 职责分离约束

  合理划分任务和相关权限，以保证多用户协同工作的安全性。

  如，公检法三权分立，互相配合，又互相监督。

4、基于角色的访问控制

- 角色互斥约束

  如果一组角色是互斥的，那么一个用户或同一个访问权限只能被分配给其中的一个角色。

  利用角色互斥约束可实现职责分离。

  例如，一个人不能又当裁判员又当运动员。

- 最小特权约束

  只给角色分配完成某工作所需的最小权力。

- 角色激活约束

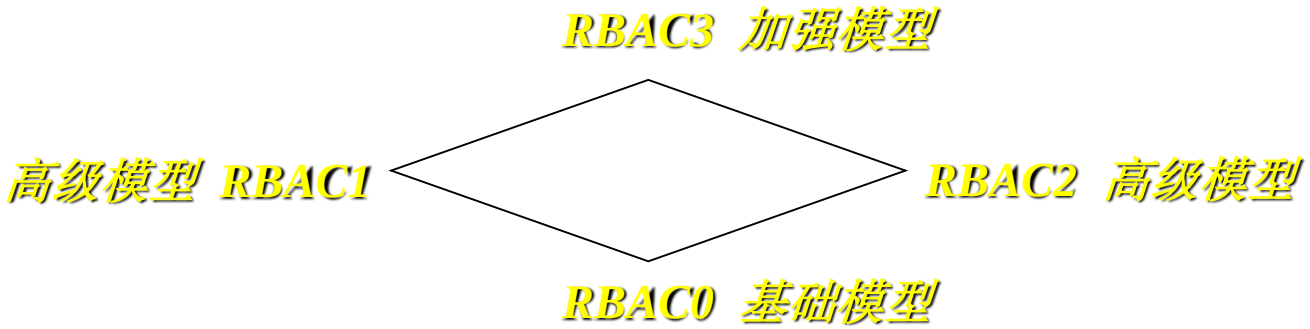
  - *激活数约束　限制一个角色同时授权和激活的数目。如总经理只有1个。*
  - *角色激活时间约束 限制一个角色激活的时间。如岗位任期制。*

4、基于角色的访问控制

RBAC96模型

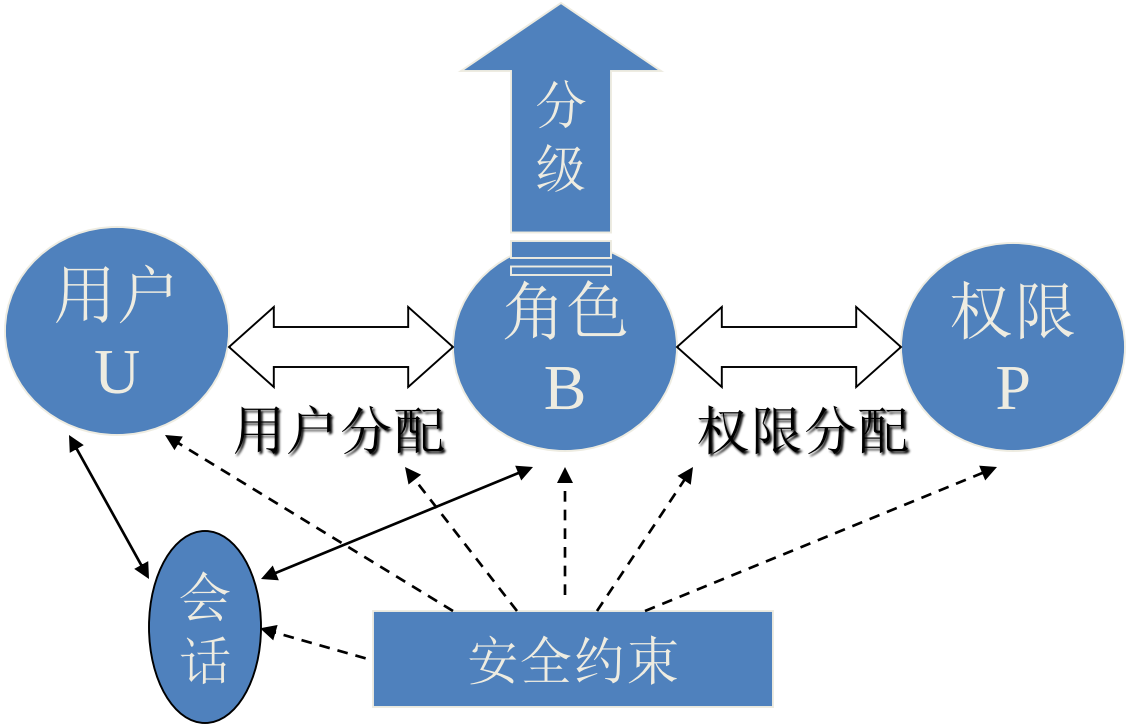
RBAC96模型包括4个层次：

- *RBAC0：基础模型*
- *RBAC1：在RBAC0的基础上增加了角色分级*
- *RBAC2：在RBAC0的基础上增加了角色和权限约束*
- *RBAC3：集成了RBAC1 和RBAC2*



4、基于角色的访问控制

RBAC96模型



LISS
空天信息安全与可信计算
教育部重点实验室

4、基于角色的访问控制

RBAC模型的优缺点

- *便于授权管理。*

  如系统管理员需要修改系统设置等内容时，必须有几个不同角色的用户到场方能操作，增强了安全性。

- *便于处理工作分级。*

  如，文件等资源分级管理。

- *利用安全约束，容易实现各种安全策略，如最小特权，职责分离等。*
- *便于任务分担，不同角色完成不同的任务。*

4、基于角色的访问控制

RBAC模型的优缺点

其缺点在于：

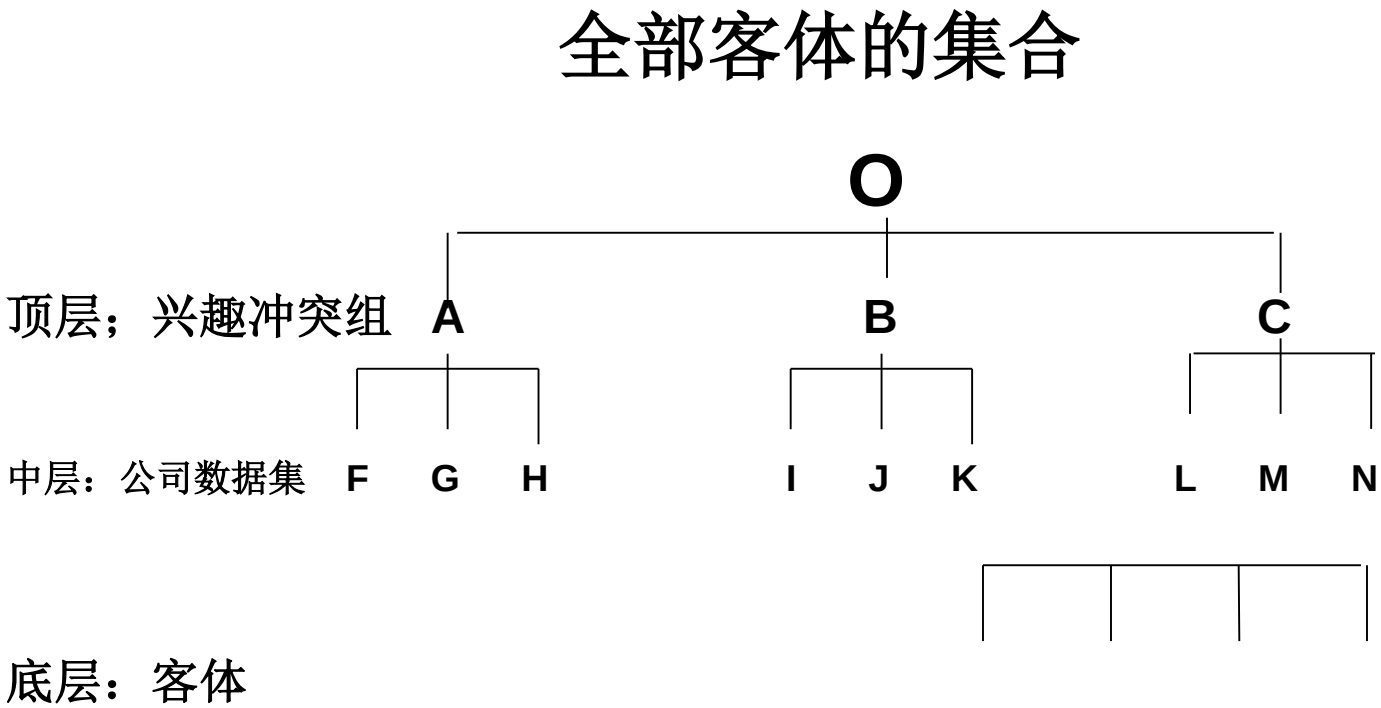
– 复杂的权限校验，对性能有一定的影响。

5、Chinese Wall 模型

- 访问数据受限于主体已经获得的对数据的访问权限，而不是数据的属性（密级）。
- Chinese Wall 模型的思想是将一些可能会产生访问冲突的数据分成不同的数据集，强制所有主体最多只能访问一个数据集，但访问哪个数据集并未受强制规则的限制。

Chinese Wall 模型

Chinese Wall 模型系统结构：



LISS
空天信息安全与可信计算
教育部重点实验室

Chinese Wall 模型

各层定义如下：

- 底层由独立的数据项组成，每项涉及一个独立的公司法人
- 中层将涉及同一公司法人的所有客体组织起来，称为“公司数据集”
- 上层将公司数据集结合成组，每个组之间互为竞争对手，称为“兴趣冲突组”

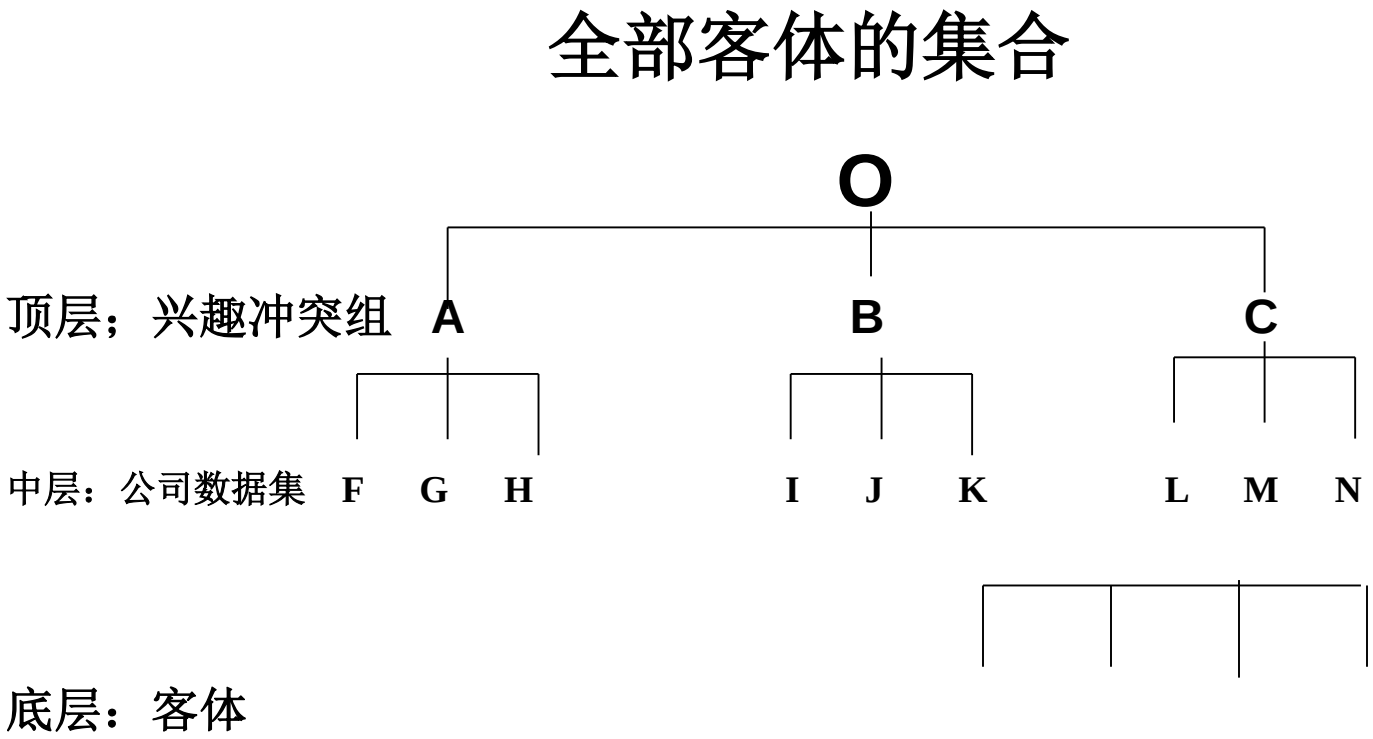
Chinese Wall 模型

Chinese Wall 模型有两种安全属性：

- **简单安全属性**
  - 用户只能访问那些与已经拥有的信息不冲突的信息.
  - 有时，在同一个兴趣冲突组中的公司数据集之间，会出现间接信息流。这是不允许发生的，违背 Chinese Wall 模型的安全策略。

Chinese Wall 模型

Chinese Wall 模型系统结构：



LISS
空天信息安全与可信计算
教育部重点实验室

Chinese Wall 模型

Chinese Wall 模型有两种安全属性：

- *属性
  - *属性对写访问做规定如下：
    - 访问必须满足简单安全属性
    - 主体能够对一个客体写访问的前提，是主体未对任何属于其他公司数据集的客体进行读访问。

Chinese Wall 模型

- 清洁信息：
  - 对公司的的敏感信息进行清洁，去除敏感信息。
  - 清洁信息可以在系统中自由地流动。

6、访问控制机制

- 访问控制列表
- 能力表
- 锁与钥匙
- 保护环

访问控制列表

访问控制矩阵

—描述访问控制机制的一种方法。

设S为全体主体的集合，$S=\{s_1, s_2, \ldots, s_m\}$

设O为全体客体的集合，$O=\{o_1, o_2, \ldots, o_n\}$

设R为全体权力的集合，$R=\{r_1, r_2, \ldots, r_l\}$

记权力矩阵为：

$$R=\begin{pmatrix} r_{11}, & r_{12}, & \ldots, & r_{1n} \\ r_{21}, & r_{22}, & \ldots, & r_{2n} \\ & & \ldots\ldots & \\ r_{m1}, & r_{m2}, & \ldots, & r_{mn} \end{pmatrix}$$

LISS
空天信息安全与可信计算
教育部重点实验室

访问控制列表

①矩阵的每一行对应一个主体，每一列对应一个客体。行与列交叉点上的元素r_{ij}表示主体s_i对客体o_j所拥有的所有权力的集合。

②当主体s_i要对客体o_j进行访问时，访问控制机制检查r_{ij}，看主体s_i是否具有对客体o_j进行访问的权力，以决定主体s_i是否可对客体o_j进行访问，以及进行什么样的访问。

访问控制列表

访问控制列表（Aaccess Control List,ACL)

通常将访问控制矩阵表示为存在于计算机中的一张表(ACL)，用户对特定系统对象例如文件目录或单个文件的存取权限。每个对象拥有一个在访问控制表中定义的安全属性。这张表对于每个系统用户有拥有一个访问权限。最一般的访问权限包括读文件（包括所有目录中的文件），写一个或多个文件和执行一个文件（如果它是一个可执行文件或者是程序的时候）。

访问控制列表

- 访问控制矩阵的列

	file1	*file2*	*file3*
Andy	rx	r	rw
Betty	rwx	r	
Charlie	rx	rw	w

- ACLs:

  file1: { (Andy, rx) (Betty, rwx) (Charlie, rx) }

  file2: { (Andy, r) (Betty, r) (Charlie, rw) }

  file3: { (Andy, rw) (Charlie, w) }

能力表

- 访问控制矩阵的行

	file1	*file2*	*file3*
Andy	rx	r	rw
Betty	rwx	r	
Charlie	rx	rw	w

对应的能力表：

- Andy: { (file1, rx) (file2, r) (file3, rw) }
- Betty: { (file1, rwx) (file2, r) }
- Charlie: { (file1, rx) (file2, rw) (file3, w) }

能力表

- 保护能力表的几种方法：
  - 标签

    与硬件字相关的比特集合。标签有两种状态：set、unset。如果是set，则普通进程能够读这个字但不能修改。否则，普通进程能够读和修改这个字。只有特权模式下的处理器才能够修改标签的状态。
  - 受保护内存

    能力表被存储在一个内存页中，进程能够读取但不能改变这些内存。
  - 密码学方法

    为防止能力表被修改，对能力表进行完整性校验。每一个能力表都有一个与之相关的密码校验和，该校验和加密保存，密钥由操作系统掌管。

锁与钥匙

- 锁与钥匙的技术同时具有访问控制表与能力表的特征。
- 锁与钥匙的特点在于它的动态性。
- 客体由一个密钥加密（锁），主体拥有解密密钥（钥匙）。

锁与钥匙

例如：

1、O’=(E1(o),…… ,En(o))

其中，客体O的副本被n个密钥加密，每个主体一个密钥。n个主体可同时访问数据。

2、O’=E1(…… En(o) ……)

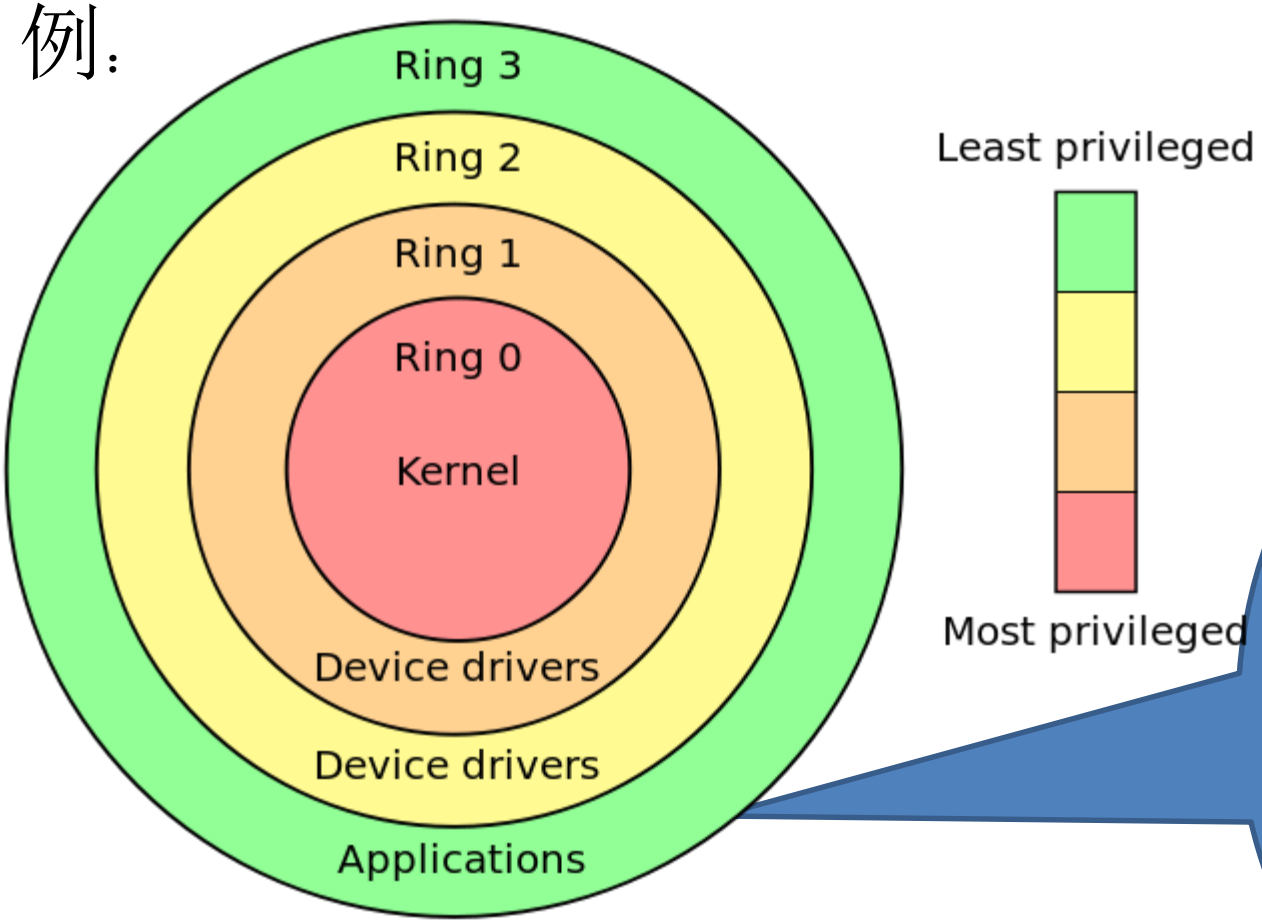
其中，客体O的被n个密钥迭代加密，每个主体一个密钥。只有当n个主体的访问请求同时发生时，数据才能够被访问。

保护环

- 保护环是信息系统的一种层次结构的特权方式。
- 给已授权的用户、程序和进程以一定的访问权，并按给定的方式操作。
- 最内层具有最小环号的环具有最高的特权，而在最外层的具有最大环号的具有最小特权。

保护环

例：



例如：X86操作系统 CPU的CPL（Current Privilege Level）、RPL（Request Privilege Level）、DPL（(Descriptor Privilege Level）

权限检查：

DPL >= max {CPL, RPL}

空天信息安全与可信计算教育部重点实验室

谢　谢！

LISS
空天信息安全与可信计算
教育部重点实验室